

Clase 337 — IA para el lado defensivo: SOC, triaje y forense

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: OWASP LLM · prácticas de SOC/DFIR (Partes 8–9) 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Aplicar la IA al **lado azul**: resumir y correlacionar alertas, asistir el triaje del SOC y apoyar el análisis forense, entendiendo dónde ayuda (velocidad, reducción de ruido) y dónde es peligrosa (falsos negativos, decisiones automáticas sin contexto). El humano sigue decidiendo.

📄 Resultados de aprendizaje

Al finalizar, el alumno podrá:

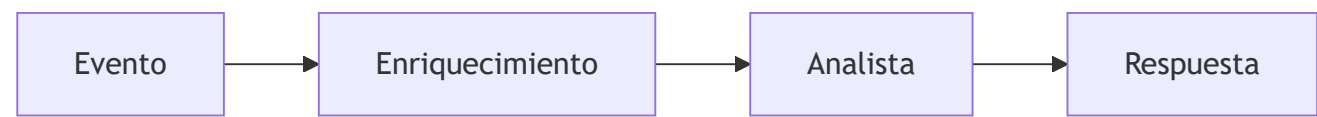
- 1. **Usar** un LLM para resumir alertas y logs y acelerar el triaje.
- 2. **Correlacionar** eventos de varias fuentes con apoyo de IA.
- 3. **Reconocer** el riesgo de falsos negativos (que la IA "tranquilece" de más).
- 4. **Mantener** al analista en el bucle para toda decisión de escalado/cierre.
- 5. **Apoyar** el análisis forense (resúmenes, hipótesis) sin sustituir la evidencia.

📖 Temas

#	Tema	Por qué importa
1	Resumen de alertas	Reduce la fatiga de alertas del SOC.
2	Correlación asistida	Une señales dispersas en una narrativa.
3	Riesgo de falso negativo	Una IA que minimiza un incidente real es peligrosa.
4	Analista en el bucle	Escalar/cerrar es decisión humana.
5	Apoyo forense	Hipótesis y resúmenes, nunca en lugar de la evidencia.

💬 Explicación en profundidad

En SOC y forense, el modelo ayuda a priorizar y resumir, pero la cadena de evidencia permanece fuera del prompt. Las salidas citan eventos, preservan originales y permiten revisión humana antes de contención.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

El resumen omite una cuenta afectada. La interfaz conserva consulta y filas fuente, y el analista corrige el alcance.

 Glosario operativo

Término	Definición
Evidence pointer	Referencia estable al artefacto original que sustenta una frase.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

 Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

 Definiciones y características

- Triage asistido** : Uso de IA para priorizar y resumir alertas, dejando la decisión de escalar al analista.
- Fatiga de alertas** : Saturación por exceso de alertas que lleva a ignorar las importantes; la IA puede aliviarla resumiendo y agrupando.
- Falso negativo** : Amenaza real no detectada/clasificada como benigna. En defensa asistida por IA es el riesgo más grave.
- Cadena de evidencia** : En forense, la IA puede sugerir hipótesis, pero las conclusiones deben apoyarse en evidencia verificable y preservada (ver clase 201).

 Herramientas y preparación

Un LLM y datos de un ejercicio defensivo (p. ej. el [lab blue-team-soc](#) o el [dfir-memoria](#)). Trabaja con datos anonimizados.

 Laboratorio guiado

- Resumen de alertas.** Da al LLM un lote de alertas del lab SOC y pídele un resumen priorizado. Contrasta con tu propia priorización.
- Correlación.** Aporta logs de dos fuentes (auth + red) y pídele la narrativa del incidente. ¿Reconstruyó la fuerza bruta → acceso → movimiento lateral?

3. **Caza del falso negativo.** Introduce un evento malicioso sutil y comprueba si la IA lo minimiza. Documenta el riesgo.
4. **Apoyo forense.** Sobre una salida de Volatility, pide hipótesis y verifica cada una con la evidencia real.
5. **Decisión.** Redacta la decisión de escalado con tu criterio, citando lo que la IA aportó y lo que verificaste.

Ejercicios

1. ¿Qué tareas del SOC acelera más un LLM?
2. Explica por qué un falso negativo asistido por IA es más peligroso que un falso positivo.
3. Diseña un flujo de triaje con IA donde el analista siempre decide.
4. ¿Cómo usarías IA en forense sin comprometer la cadena de evidencia?
5. ¿Qué datos del SOC no enviarías a un modelo externo?

Reto verificable

Toma un incidente del lab, genera con IA un resumen + narrativa y **valida** cada afirmación contra los logs reales.

Criterio de aceptación: entregas el resumen, marcas al menos una afirmación imprecisa de la IA y la corriges con la evidencia; la decisión de escalado es tuya y está justificada.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Cerrar una alerta porque "la IA dijo que era benigna"	Falso negativo. El analista decide con evidencia.
Automatizar respuestas sin supervisión	Riesgo de acción errónea a escala. Mantén aprobación humana.
Enviar logs con PII a un modelo externo	Fuga de datos. Anonimiza o usa modelo aprobado.
Tomar hipótesis forenses como conclusiones	La IA sugiere; la evidencia concluye.

Preguntas frecuentes

? ¿La IA reemplaza a los analistas del SOC? No; reduce el trabajo repetitivo y acelera el triaje, pero el criterio, el contexto de negocio y la decisión de escalar siguen siendo humanos.

? ¿Puedo automatizar la respuesta (SOAR) con IA? Con mucho cuidado y aprobación humana en las acciones con impacto. Una respuesta automática equivocada puede causar más daño que el incidente.

Referencias

- Parte 8 (SOC/detección) y Parte 9 (DFIR) del programa.
- [OWASP Top 10 for LLM Applications](#)



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 336 — OSINT y auditoría web con agentes de IA](#)



Siguiente clase

[Clase 338 — Generación de informes y flujos de trabajo con IA](#)